Final Project

Sai Naga Sabarish Yerramsetty
Department of Cybersecurity of Information Assurance
University of Central Missouri
CYBR 5720 : Cyber Security Policies & Risk Management Dr. Richard Morphy
December 04, 2025

ACCEPTABLE USE POLICY

Purpose

The purpose of this policy is to define acceptable and responsible use of organizational computing resources, networks, and data. It ensures that employees, contractors, and students safeguard information systems and comply with standards and regulations, aligning with NIST CSF 2.0 functions: Govern, Identify, Protect, Detect, Respond, and Recover. (Parmar & Miles, 2024)

Audience

All users of the organization are subject to this policy, including:

• Full-time, part-time, and temporary workers;

• Vendors and contractors having system access;

• Students or interns utilizing company resources

• Executive and administrative leadership with higher account rights

Policy Contents

You CAN do the following:

• Utilize computer resources only for study, education, or business.

• Make responsible use of allotted accounts and devices, making sure that safe setups and strong passwords are used.

• Keep devices updated, lock displays, and report thefts to safeguard equipment from both digital and physical dangers.

You CANNOT do the following:

• Acquire or try to obtain illegal access to data, networks, or systems. (Hagen, Sivertsen & Rong, 2008)

• Data access or sharing without express permission. (Muslukhov et al., 2013)

• Take part in forbidden activities, such as:

  o Sexually explicit or pornographic content (Mecham et al., 2019)

  o Activities connected to the military that are not authorized by the organization

  o Any kind of gambling

o Individual internet shopping or non-business dealings

Exemption Process

Users must submit a written request to the Information Security Office if they need an exemption from this policy (for valid commercial, training, or research purposes). The Chief Information Security Officer (CISO) or another designated authority must review the approval.

Enforcement

Discipline for breaking this policy may include:

• Termination of system access.

• Written warnings or corrective training.

• Suspension or termination of employment or a contract.

• Legal action, if appropriate

Mapped Controls

GV.PO-01 – Cybersecurity policies are established and communicated

AC-1 Policy and Procedures
AT-1 Policy and Procedures

PR. AA-01 – Identities are verified and managed to prevent unauthorized access

AC-2 Account Management
IA-2 Identification and Authentication

PR.DS-01 – Data is protected from unauthorized access, disclosure, or modification

SC-28 Protection of Information at Rest
SC-12 Cryptographic Key Management

PR.PT-01 – Least privilege and system access restrictions are enforced

AC-6 Least Privilege AC-17 Remote Access

• **AU-11 –** Audit Record Retention

Version Control

Version	Modified Date	Approved Date	Approved By	Comments
0.1	September 2025	September 2025	Dr. Richard Morphy	Initial draft of *Acceptable Use Policy* for COMPANYNAME.
0.2	December 2025	December 2025	700777106	You CAN do the following" section mixes business and academic tone; needs consistency.
0.3	December 2025	December 2025	700772921	One reference (Mauthner & Parry, 2013) is listed but never cited inside the policy body.
1.0	December 2025	December 2025	Dr. Richard Morphy	Final version with all the sections and citations.

ASSET MANAGEMENT POLICY

Purpose

Establishing guidelines for the backup, storage, and recovery of corporate data assets is the aim of this asset management policy. In addition to guaranteeing business continuity and legal and regulatory compliance, effective backup procedures protect data from unintentional loss, corruption, cyberattacks, and natural catastrophes. This emphasizes resilience through dependable data management, which is in line with the NIST Cybersecurity Framework (CSF) 2.0 functions: Identify, Protect, Detect, Respond, and Recover (Parmar & Miles, 2024).

Audience

All users of the organization are subject to this policy, including:

• All workers, subcontractors, suppliers, and pupils who handle company information;

• IT managers are in charge of the backup infrastructure;

• Executive leadership is responsible for compliance and risk management;

Policy Contents

You CAN do the following:

• Only use disks, platforms, or cloud services that have been approved by the company to store and backup data.

• As directed by the Information Security Office, carry out automated backups on a scheduled basis.

• To avoid unwanted access, encrypt backups both during transmission and at rest (Hagen, Sivertsen & Rong, 2008).

• To guarantee functionality and dependability, test backup recovery processes on a frequent basis (Zhang et al., 2019).

• Maintain backups in accordance with commercial, legal, or regulatory obligations (Mauthner & Parry, 2013).

You CANNOT do the following:

• Store private company information on external USB drives, personal devices, or unapproved cloud services.

• Automated backup schedules can be disabled or changed without written consent.

• Without express consent, backup data may be shared, copied, or deleted from organizational control (Muslukhov et al., 2013).

• Keep corrupted or out-of-date backup files after the allotted time, as this could jeopardize recovery efforts.

Exemption Process

The Information Security Office must receive a formal request from users who need to be exempted from the backup policy. Before approving a request, the Chief Information Security Officer (CISO) or a designee will evaluate it in light of operational requirements, legal requirements, and possible hazards.

Enforcement

Infractions of this policy could lead to:

• The backup access rights are terminated.

• Warnings in writing and remedial instruction.

• Termination or suspension of contracts or employment.

• Financial and legal repercussions if improper data processing leads to regulatory infractions.

Mapped Controls

ID.AM-05 – Resources, including hardware, software, and data, are prioritized based on classification, criticality, and business value.

- CM-8: System Component Inventory
- PM-5: System Inventory

PR.DS-04 – Adequate capacity planning and redundancy measures are implemented to ensure data integrity.

- CP-9: Information System Backup
- CP-10: Information System Recovery

PR.IP-04 – Backups of information are conducted, maintained, and tested periodically.

- CP-6: Alternate Storage Site
- CP-7: Alternate Processing Site

RC.RP-01 – Recovery planning and processes are executed during or after an incident.

- IR-4: Incident Handling
- CP-2: Contingency Plan

Version Control

Version	Modified Date	Approved Date	Approved By	Comments
0.1	September 2025	September 2025	Dr. Richard Morphy	Initial draft of *Asset Management Policy* for COMPANYNAME.
0.2	December 2025	December 2025	700777106	“Pupils” in Audience section is inconsistent; use “students.”
0.3	December 2025	December 2025	700772921	“Backup access rights are terminated” needs clarification specify user or administrator privileges.
1.0	December 2025	December 2025	Dr. Richard Morphy	Final version with all the sections and citations.

LOGGING STANDARD

Purpose

The purpose of this Logging Standard is to establish consistent requirements for the collection, storage, monitoring, and analysis of system and network logs. Effective logging enables the detection of anomalies, unauthorized access attempts, and system failures while supporting incident response and compliance obligations. This aligns with the NIST Cybersecurity Framework (CSF) 2.0 functions: **Identify, Protect, Detect, Respond, and Recover** (Parmar & Miles, 2024).

Audience

This standard applies to all individuals who create, manage, or monitor logs within the organization, including:

• System administrators and security analysts managing servers, applications, or network infrastructure.

• Contractors or third-party service providers with monitoring or maintenance responsibilities.

• IT leadership and compliance officers responsible for audit and investigation functions.

Policy Contents

You CAN do the following:

• Enable logging for all critical systems, including firewalls, IDS/IPS, endpoint devices, and authentication systems.

• Store logs in centralized, secured log management or SIEM platforms to support correlation and incident response (Kent & Souppaya, 2006).

• Retain logs for a minimum of 12 months or longer based on regulatory or operational requirements (Zhou et al., 2021).

• Protect log integrity using hashing, access controls, and encryption during storage and transmission (Scarfone et al., 2023).

• Review and analyze logs periodically to detect suspicious activity or policy violations (Casey & Stellatos, 2008).

You CANNOT do the following:

• Disable system or application logging without explicit written authorization.

• Delete or alter log files to conceal activity or avoid accountability.

• Store sensitive logs in unsecured or personal storage systems.

• Share log data externally without proper authorization from the Information Security Office.

Exemption Process

If an operational need requires deviations from this Logging Standard, a formal exemption request must be submitted to the **Information Security Office**. The **Chief Information Security Officer (CISO)** or an appointed designee will review the request based on operational justification, risk assessment, and regulatory obligations.

Enforcement

Violations of this Logging Standard may result in:

• Revocation of system or administrative access.

• Written warnings, retraining, or disciplinary actions.

• Suspension or termination of employment or contractual engagement.

• Legal or regulatory action for tampering or destruction of log data

Mapped Controls

CSF Subcategories:

• DE.AE-03 – Event data is collected and correlated to detect and analyze anomalies.

• PR.PT-05 – Logging is implemented to record user and system activities.

• RS.AN-01 – Incident analysis is supported by relevant and timely log information.

• RC.IM-02 – Post-incident reviews leverage log data to improve response.

NIST SP 800-53r5 Controls:

• AU-2 – Event Logging

• AU-6 – Audit Record Review, Analysis, and Reporting

• AU-9 – Protection of Audit Information

• SI-4 – System Monitoring

• IR-5 – Incident Monitoring

Version Control

Version	Modified Date	Approved Date	Approved By	Comments
0.1	October 2025	October 2025	Dr. Richard Morphy	Initial draft of Logging Standard for Sabarish's Company.
0.2	December 2025	December 2025	700777106	"You CAN do the following" list lacks consistent punctuation; ensure all items end with periods.
0.3	December 2025	December 2025	700772921	Clarify "Protect log integrity using hashing" specify algorithm or control type (e.g., SHA-256).
1.0	December 2025	December 2025	Dr. Richard Morphy	Final version with all the sections and citations.

INFORMATION DISPOSAL STANDARD

Purpose

The purpose of this Information Disposal Standard is to establish secure and consistent methods for the destruction of sensitive data and physical media. This ensures that information is rendered irretrievable, protecting confidentiality and compliance with organizational, legal, and regulatory requirements. The standard aligns with the NIST Cybersecurity Framework (CSF) 2.0 functions: **Identify, Protect, Detect, Respond, and Recover** (Parmar & Miles, 2024).

Audience

This standard applies to all individuals who create, manage, or monitor logs within the organization, including:

• System administrators and security analysts managing servers, applications, or network infrastructure.

• Contractors or third-party service providers with monitoring or maintenance responsibilities.

• IT leadership and compliance officers responsible for audit and investigation functions.

Policy Contents

You CAN do the following:

• Dispose of electronic media (e.g., hard drives, SSDs, USBs, optical disks) and physical records (e.g., printed documents) in accordance with NIST SP 800-88 Revision 1 guidelines.

• Use approved methods such as clearing, purging, degaussing, or physical destruction depending on data sensitivity and medium type (Reardon et al., 2013).

• Maintain detailed disposal logs documenting date, method, and responsible personnel.

• Partner with certified destruction vendors who meet industry compliance standards (GDPR, HIPAA, ISO/IEC 27040).

• Verify and document disposal through audit trails to ensure accountability and verification (**Kandala & Devanbu, 2021**).

You CANNOT do the following:

• Dispose of sensitive information through unsecured trash bins, unverified software wipes, or unauthorized third-party services.

• Retain unnecessary or expired information beyond retention schedules.

• Attempt to recover, copy, or share data from devices marked for disposal.

• Ignore disposal verification or fail to document destruction in compliance reports.

Exemption Process

Departments requiring exceptions for legal holds, investigations, or operational necessity must submit a written exemption request to the **Information Security Office**. The **Chief Information Security Officer (CISO)** or an authorized delegate will review and approve the request based on business, legal, or regulatory justification.

Enforcement

Violations of this Information Disposal Standard may result in:

• Revocation of system or facility access.

• Written reprimands, retraining, or disciplinary actions.

• Suspension or termination of employment or contracts.

• Legal or financial penalties for non-compliance with data protection laws.

Mapped Controls

CSF Subcategories:

- **PR.DS-03** – Data is securely removed when no longer needed.
- **PR.PT-05** – Disposal mechanisms protect the confidentiality of data.
- **ID.AM-06** – Data assets are managed throughout their lifecycle.

NIST SP 800-53r5 Controls:

- **MP-6** – Media Sanitization
- **MP-7** – Media Use
- **PL-2** – System and Communications Protection Policy and Procedures
- **AU-11** – Audit Record Retention

Version Control

Version	Modified Date	Approved Date	Approved By	Comments
0.1	October 2025	October 2025	Dr. Richard Morphy	Initial draft of Information Disposal Standard for Sabarish's Company
0.2	December 2025	December 2025	700777106	In Audience section, "log management" is incorrectshould refer to "information disposal."
0.3	December 2025	December 2025	700772921	Add citation for GDPR/HIPAA/ISO references to strengthen compliance validity.
1.0	December 2025	December 2025	Dr. Richard Morphy	Final version with all the sections and citations.

LOGGING PROCEDURE

Purpose

The purpose of this procedure is to define the steps required to enable, configure, and forward system logs from a selected server to the company's centralized Security Information and Event Management (SIEM) platform.This supports the *Logging Standard – Sai Naga Sabarish Yerramsetty | 700771967* and ensures compliance with NIST SP 800-92 guidelines for secure log management and alignment with the NIST Cybersecurity Framework (CSF) functions: *Identify, Protect, Detect, Respond, and Recover* (Kent & Souppaya, 2006; Parmar & Miles, 2024).

Audience

This procedure applies to system administrators, security engineers, and IT personnel responsible for configuring and maintaining server logging functions.It also applies to those who review, analyze, or forward logs to the **COMPANYNAME-SIEM** for centralized security monitoring (Reardon et al., 2013).

Procedure Steps

Server Selected: Ubuntu Linux Server

Step 1: Log in to the Ubuntu server using SSH with administrative privileges.
Step 2: Install the rsyslog service if it is not already installed.

Step 3: Edit the rsyslog configuration file to define the forwarding rule.

Step 4: Add the following line to forward all logs securely to the SIEM:Step 5: Save and close the configuration file.
" *.* @@*10.10.10.250:514* " ("@@" specifies TCP with encryption.)

This supports secure, real-time log forwarding as outlined in NIST SP 800-92 and by Scarfone et al. (2023).

Step 5:Restart the rsyslog service and verify that the logs are successfully being sent to COMPANYNAME-SIEM (10.10.10.250)
Step 6:Validate that only authorized users can access the logs and confirm encryption during transmission to preserve confidentiality and integrity (Huth et al., 2020).

Audit Trail

• Log configuration changes must be documented with date, time, and responsible user.

• Rsyslog configuration files should be backed up to /var/backups/rsyslog/.

• SIEM ingestion reports should be reviewed monthly to verify log forwarding integrity.

Mapped Controls

CSF Subcategories:

• **DE.AE-03 – Event data is collected and correlated to detect and analyze anomalies.**

• **PR.PT-05 – Logging is implemented to record user and system activities.**

• **RS.AN-01 – Incident analysis is supported by relevant and timely log information.**

NIST SP 800-53r5 Controls:

• **AU-2 – Event Logging**

• **AU-6 – Audit Record Review, Analysis, and Reporting**

• **AU-9 – Protection of Audit Information**

• **SI-4 – System Monitoring**

Version Control

Version	Modified Date	Approved Date	Approved By	Comments
0.1	October 2025	October 2025	Dr. Richard Morphy	Initial draft of Logging Procedure for Sabarish's Company SIEM.
0.2	December 2025	December 2025	700777106	Step 4 missing proper punctuation before configuration example; add colon.
0.3	December 2025	December 2025	700772921	Add details for verifying SIEM connection success in Step 6 for completeness.
1.0	December 2025	December 2025	Dr. Richard Morphy	Final version with all the sections and citations.

INFORMATION DISPOSAL PROCEDURE

Purpose

This procedure establishes a standardized method for securely disposing of electronic storage media, ensuring the complete destruction of sensitive information in accordance with the Information Disposal Standard and NIST Special Publication 800-88 Rev. 1: Guidelines for Media Sanitization (National Institute of Standards and Technology [NIST], 2014). It applies to all organizational assets containing confidential or regulated data, including hard disk drives (HDDs), solid-state drives (SSDs), USBs, and optical media.

Audience

This procedure applies to all personnel responsible for handling, sanitizing, or destroying electronic media within the organization, as required under NIST SP 800-88 Rev. 1 guidelines (National Institute of Standards and Technology [NIST], 2014). This includes:

- **System administrators** responsible for performing media sanitization or physical destruction in compliance with approved organizational tools and processes (Huth et al., 2020).
- **Security analysts and compliance officers** verifying that sanitization activities meet the requirements of the Information Disposal Standard and relevant NIST controls (Kandala & Devanbu, 2021).
- **IT asset managers** tracking data lifecycle status and maintaining disposal documentation for audits (Chauhan & Singh, 2017).
- **Certified third-party vendors** contracted for media destruction services that comply with ISO/IEC 27040 and NIST standards (Huth et al., 2020).

All individuals involved in disposal must be trained on this procedure to ensure secure, consistent, and compliant handling of sensitive data throughout its lifecycle (NIST, 2014).

Procedure Steps

1. Identification and Preparation

The responsible system administrator identifies devices or media scheduled for disposal based on retention policies or decommissioning schedules. Before proceeding, the administrator must verify that no active legal holds, investigations, or exemptions apply. Each asset's serial number, device type, and data classification are recorded in the Media Disposal Log for accountability (Huth et al., 2020).

2. Selection of Sanitization Method

The sanitization method must correspond to the device type and sensitivity of stored information, following NIST SP 800-88 Rev. 1 guidelines (NIST, 2014).

- Magnetic Hard Drives (HDDs):
    - Connect the drive to an approved sanitization system (e.g., WipeDrive Enterprise or Blancco Drive Eraser).
    - Launch the program and select the target drive.
    - Choose a 7-pass DoD 5220.22-M wipe standard or NIST "Clear" method to overwrite all sectors.
    - Verify successful completion through software-generated reports (Chauhan & Singh, 2017).
- Solid-State Drives (SSDs):
    - Use the manufacturer's Secure Erase or Cryptographic Erase function, as defined in NIST 800-88 (NIST, 2014).
    - Confirm the operation through diagnostic output or built-in verification tools.
    - If verification fails, physically destroy the SSD via shredding or pulverization (Kandala & Devanbu, 2021).
- Removable Media (USBs, SD Cards, Optical Disks):
    - For USBs/SD Cards, perform a full overwrite using secure erase utilities such as the Linux shred command or DBAN.

- For optical disks, apply physical destruction using cross-cut shredding or disintegration (Huth et al., 2020).

3. Verification and Documentation

A secondary staff member must verify the sanitization or destruction results, ensuring integrity and compliance with organizational policy (Chauhan & Singh, 2017). Both the operator and verifier sign the Media Disposal Log, which includes:

- Media type and serial number
- Date and sanitization method
- Verification outcome and personnel signatures

4. Vendor Disposal and Chain of Custody

When destruction is outsourced, only certified vendors compliant with ISO/IEC 27040 and NIST 800-88 should be used. Each vendor must provide a Certificate of Destruction as proof of compliance (Huth et al., 2020). All disposal documentation must be retained for at least 12 months to support internal or external audits (Kandala & Devanbu, 2021).

5. Enforcement and Compliance

Failure to follow this procedure may result in disciplinary action, loss of system privileges, or legal penalties, as detailed in the *Information Disposal Standard* (Huth et al., 2020).

Mapped Controls

CSF Subcategories:

• **PR.DS-03 –** Data is securely removed when no longer needed.
• **PR.PT-05 –** Disposal mechanisms safeguard the confidentiality of data.
• **ID.AM-06 –** Data assets are managed throughout their lifecycle.

NIST SP 800-53r5 Controls:

• **MP-6 –** Media Sanitization
• **MP-7 –** Media Use
• **PL-2 –** System and Communications Protection Policy and Procedures

Version Control

Version	Modified Date	Approved Date	Approved By	Comments
0.1	November 2025	November 2025	Dr. Richard Morphy	Initial draft of Information Disposal Procedure for Sabarish's Company.
0.2	December 2025	December 2025	700777106	Add step for ensuring disposal documentation retention duration (12 months) to clarify compliance.
0.3	December 2025	December 2025	700772921	Fix inconsistent bullet formatting in "Procedure Steps" section (mix of • and o symbols).
1.0	December 2025	December 2025	Dr. Richard Morphy	Final version with all the sections and citations.

References

- Casey, E., & Stellatos, G. J. (2008). *The impact of full disk encryption on digital forensics.* ACM SIGOPS Operating Systems Review, 42(3), 93–98. https://doi.org/10.1145/1368506.1368517
- Chauhan, D., & Singh, A. (2017). *Study on need of data sanitization and sanitization techniques for memory devices.* Open Access International Journal of Science and Engineering (OAIJSE), 2(11), 1–5. https://www.oaijse.com/VolumeArticles/FullTextPDF/97_OAIJSE_STUDY_ON_NEED_OF_DATA_SANITIZATION_AND_SANITIZATION_TECHNIQUES_FOR_MEMORY_DEVICES.pdf
- Hagen, J. M., Sivertsen, T. K., & Rong, C. (2008). *Protection against unauthorized access and computer crime in Norwegian enterprises.* Journal of Computer Security, 16(3), 341–366. https://doi.org/10.3233/JCS-2008-16305
- Huth, C. L., Miller, D. R., & Snyder, J. F. (2020). *Secure destruction of digital information: Best practices and emerging trends.* Journal of Information Security and Applications, 54, 102592. https://doi.org/10.1016/j.jisa.2020.102592
- Kandala, S. S., & Devanbu, P. (2021). *Secure data deletion: Challenges, techniques, and future directions.* Journal of Information Security and Applications, 61, 102928. https://doi.org/10.1016/j.jisa.2021.102928
- Kent, K., & Souppaya, M. (2006). *Guide to Computer Security Log Management (NIST SP 800-92).* National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-92
- Mauthner, N. S., & Parry, O. (2013). *Open access digital data sharing: Principles, policies and practices.* Social Epistemology, 27(1), 47–67. https://doi.org/10.1080/02691728.2012.760663
- Muslukhov, I., Boshmaf, Y., Kuo, C., Lester, J., & Beznosov, K. (2013). *Know your enemy: The risk of unauthorized access in smartphones by insiders.* Proceedings of the

15th International Conference on Human-Computer Interaction with Mobile Devices and Services, 271–280. https://doi.org/10.1145/2493190.2493223

- National Institute of Standards and Technology. (2014). *NIST Special Publication 800-88 Rev. 1: Guidelines for Media Sanitization.* U.S. Department of Commerce. https://doi.org/10.6028/NIST.SP.800-88r1
- Parmar, M., & Miles, A. (2024, May). *Cyber Security Frameworks (CSFs): An assessment between the NIST CSF v2.0 and EU standards.* In *2024 Security for Space Systems (3S)* (pp. 1–7). IEEE. https://doi.org/10.23919/3S60530.2024.10592293
- Reardon, J., Basin, D., & Čapkun, S. (2013). *Secure data deletion from persistent media.* Proceedings of the ACM Conference on Computer and Communications Security (CCS), 271–284. https://doi.org/10.1145/2508859.2516728
- Scarfone, K., Mell, P., & Kent, K. (2023). *Security logging and monitoring controls.* Journal of Cybersecurity Research, 7(2), 101–118. https://doi.org/10.1109/JCSR.2023.0001
- Zhang, K., Zhou, Y., Chen, X., & Xu, X. (2019). *Data backup and recovery for cloud computing: A survey.* Future Generation Computer Systems, 98, 443–458. https://doi.org/10.1016/j.future.2019.03.019
- Zhou, X., Cao, J., & Zhang, Y. (2021). *Secure and scalable log management for cloud environments.* Future Generation Computer Systems, 115, 230–240. https://doi.org/10.1016/j.future.2020.09.023